OmniRail Engine — Blueprint v1.1

Nov 9, 2026 · @devaldicaliesta

Status dokumen: siap sebagai acuan awal, belum divalidasi. Belum ada perbandingan dengan LiteLLM dan Presidio, isi policy pack belum ditinjau staf kepatuhan, teks Pasal 56 dan Pasal 36 sampai 39 UU PDP belum dicek ke naskah resmi, dan detail API Gemini perlu dicek sekali lagi ke dokumentasi resmi sebelum adapter ditulis.

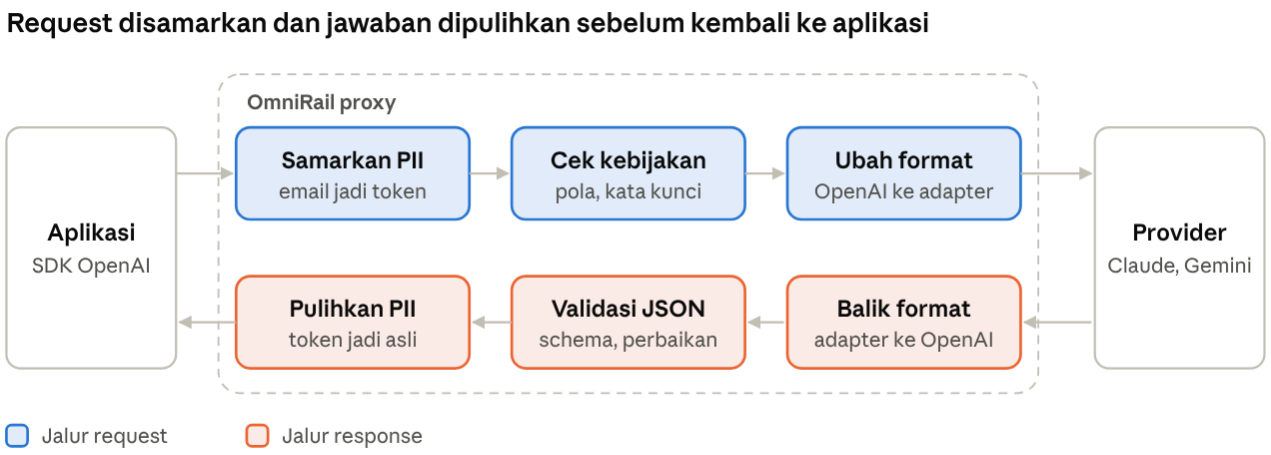
1. Ringkasan dan posisi

OmniRail adalah proxy open-source yang berdiri di depan LLM: menyamarkan data pribadi, menegakkan kebijakan, dan memvalidasi output, dalam satu binary tanpa GPU. Versi 1.1 mempersempit v1.0: OmniRail **bukan** gateway pengganti, melainkan lapisan guard yang bisa berdiri sendiri atau dipasang di depan gateway lain.

- **Posisi:** guard deterministik-first, footprint kecil, overhead latensi yang diukur dan dipublikasikan.
- **Pengguna:** umum (tim internal, startup); kebutuhan sektor teratur dilayani lewat *policy pack*.
- **Hipotesis diferensiasi (perlu divalidasi dengan calon pengguna):** entitas Indonesia (NIK, NPWP, rekening, nomor +62), tokenisasi PII yang reversibel, dan mode *shadow* untuk menguji kebijakan sebelum diberlakukan.
- **Pembangun:** satu orang, bertahap.
- **Non-goals v1:** fallback dan load balancing antar-provider, tracking biaya, dasbor, verifikasi grounding RAG, moderasi semantik, tool/MCP governance.

Bentuk: engine berbentuk proxy atau service yang dilewati semua permintaan ke LLM, dengan antarmuka web kecil untuk mencoba. Bukan skill, karena skill adalah instruksi untuk model dan tidak bisa menegakkan kontrol sebelum data terkirim. Bukan aplikasi system tray, yang hanya mungkin menjadi pembungkus opsional untuk pemakaian di laptop.

2. Arsitektur dan alur



alur OmniRail · 3 langkah request, 3 langkah response

Inti (PII, kebijakan, validasi) ditulis sebagai pustaka terpisah dari lapisan HTTP, sehingga nanti bisa dipasang sebagai proxy mandiri, sidecar untuk gateway lain, atau SDK tanpa menulis ulang. Pada MVP hanya proxy mandiri yang dibangun. Aplikasi cukup mengganti `base_url` ke OmniRail; token PII (misalnya `<EMAIL_1>`) hanya hidup di memori selama satu request.

3. Scope MVP

MVP membuktikan satu hal: request bisa melewati proxy, datanya tersamarkan, jawaban dari provider kembali utuh dan valid. Semua yang tidak mendukung bukti itu ditunda.

Area	Masuk MVP	Ditunda
API klien	`POST /v1/chat/completions` (format OpenAI), non-streaming, teks saja	Streaming, tool call, gambar, format klien asli Anthropic dan Gemini
Upstream	Adapter OpenAI (passthrough), Anthropic Messages API, dan Gemini API; Ollama untuk uji lokal	Provider lain, fallback antar-provider
PII	Regex + validasi (Luhn untuk kartu, format NIK 16 digit), tokenisasi reversibel per request; credentials (API key, JWT, private key, password di connection string) dideteksi dan diblokir, tidak ditokenisasi	NER untuk nama dan alamat
Kebijakan	Deny-list pola, batas panjang input, blokir topik berbasis kata kunci	Topic control semantik, classifier injection

Area	Masuk MVP	Ditunda
Output	Validasi JSON schema + perbaikan sintaks otomatis	Grounding RAG
Operasional	Config YAML, API key proxy, log terstruktur, metrik OpenTelemetry, fail mode per rute	Rate limiting, Redis, dasbor
Distribusi	Satu binary, README, benchmark latensi, omnirail eval, tampilan uji satu halaman	SDK Python/TypeScript, adapter LiteLLM

4. Konfigurasi dan policy pack

Semua perilaku diatur satu file `omnirail.yaml`. *Policy pack* adalah bundel aturan siap pakai yang dimuat lewat `policy_pack`; aturan di file ini menimpa isi pack. Pack pertama yang dibuat: `id-general`.

```
version: "1.1"
mode: enforce              # enforce | shadow (catat tanpa memblokir)
policy_pack: id-general    # id-general | id-fintech | id-ecommerce | id-
instansi

server:
  listen: "0.0.0.0:8080"
  api_keys: ["${OMNIRAIL_KEY}"]   # kunci untuk aplikasi, bukan kunci
provider

upstream:
  providers:
    anthropic: { api_key: "${ANTHROPIC_API_KEY}" }
    gemini:    { api_key: "${GEMINI_API_KEY}" }
    openai:    { api_key: "${OPENAI_API_KEY}" }
    ollama:    { base_url: "http://localhost:11434" }
  model_map:               # nama model di aplikasi -> provider + model asli
    default: { provider: anthropic, model: "claude-sonnet-5-5" }
    # tambah entri untuk gemini atau openai dengan ID model dari penyedianya

ingress:
  pii:
    action: tokenize       # tokenize | redact
    restore_on_egress: true
    entities: [email, phone_id, credit_card, nik, npwp, bank_account]
  credentials:
```

```
    action: block          # block | redact (bukan tokenisasi)
    detectors: [api_key, jwt, private_key, connection_string,
password_assignment]
  policy:
    max_input_chars: 20000
    allowed_providers: [anthropic, gemini, openai, ollama]  # pack instansi
bisa membatasi ke ollama
    deny_patterns: ["abaikan instruksi sebelumnya"]
    blocked_keywords: ["politik"]

egress:
  json:
    schema_file: "./schemas/output.json"
    repair_syntax: true

fail_mode:
  ingress: closed          # PII/kebijakan gagal -> tolak request
  egress: open             # validasi output gagal -> teruskan + catat

audit:
  log_policy_version: true # versi dan hash kebijakan aktif dicatat di tiap
request

logging:
  store_raw_prompts: false # default aman
```

Dua perbedaan dari v1.0: `allowed/blocked` topik diganti kata kunci eksplisit (klasifikasi semantik menunggu Fase berikutnya), dan setiap rute punya `fail_mode` yang jelas.

5. Customisasi

OmniRail dibuat umum di inti dan disesuaikan per sektor lewat empat tingkat. MVP hanya mengerjakan tingkat 1 dan 2, tetapi format pack dirancang dari awal agar tingkat 3 tidak memaksa perubahan arsitektur.

Tingkat	Isi	Kapan
1. Konfigurasi	Nyalakan atau matikan entitas, `fail_mode`, `mode: shadow`	MVP
2. Aturan kustom	Regex, daftar kata, dan entitas buatan pengguna di `omnirail.yaml`	MVP

Tingkat	Isi	Kapan
3. Policy pack	Bundel aturan yang bisa dipasang dan dibagikan (`id-general` , `id-fintech` , dan seterusnya)	Setelah rilis awal
4. Kode kustom	Guard buatan pengguna lewat webhook HTTP atau modul WASM	Fase lanjut, setelah inti stabil

Struktur sebuah pack:

```
policy-packs/id-general/
  pack.yaml          # nama, versi, deskripsi, versi OmniRail minimum
  entities.yaml      # definisi entitas
  policy.yaml        # deny_patterns, blocked_keywords, batas input
  tests/
    should_detect.txt   # kalimat yang wajib terdeteksi
    should_ignore.txt   # kalimat yang tidak boleh terdeteksi
```

Contoh satu entitas di `entities.yaml` :

```
entities:
  - name: nik
    pattern: '\b\d{16}\b'
    validator: nik_format      # validator bawaan, bukan regex saja
    context_words: [nik, ktp]  # kata di sekitar yang menaikkan keyakinan
    action: tokenize
```

Aturan main:

- **Urutan prioritas:** `omnirail.yaml` pengguna menimpa pack, dan pack menimpa default.
- **Pack wajib punya tes.** Pack tanpa `should_detect` dan `should_ignore` ditolak saat dimuat, agar kualitas bisa dijaga dan false positive terlihat.
- **YAML tetap deklaratif.** Kondisi dan logika kompleks tidak ditambahkan ke YAML; itu tugas tingkat 4.
- **Kode kustom dibatasi.** Tingkat 4 memerlukan batas waktu, batas memori, dan izin eksplisit, dan tidak dibangun sebelum tahap 5 roadmap selesai.

6. Policy pack prioritas, regulasi, dan kontrol perubahan

Empat pack direncanakan. Hanya `id-general` yang masuk MVP; sisanya dibangun satu per satu dari dokumen regulasi asli dan ditinjau orang yang bertanggung jawab atas kepatuhan.

Pack	Sasaran	Isi awal	Status
`id-general`	Umum	PII Indonesia dan credentials	Pack pertama (MVP)
`id-fintech`	Bank, multifinance, fintech	Aturan rekening dan kartu lebih ketat, credentials diblokir, log tanpa data mentah, daftar provider yang diizinkan	Kedua; dari dokumen regulasi asli
`id-ecommerce`	Marketplace, toko online	Alamat pengiriman, telepon pembeli, data pembayaran; nomor resi dan nomor pesanan tidak boleh salah terdeteksi	Setelah fintech; ujian false positive utama
`id-instansi`	Instansi pemerintah	NIP, NIK, penanda klasifikasi dokumen, pembatasan provider (misalnya hanya model lokal lewat Ollama)	Setelah rilis awal, sesuai kebutuhan instansi

Dasar regulasi yang perlu ditinjau (bukan daftar lengkap, dan OmniRail tidak menafsirkannya):

- **UU 27/2022 tentang Pelindungan Data Pribadi, Pasal 56.** Mengatur transfer data pribadi ke luar wilayah Indonesia lewat tiga jalur: negara tujuan dengan pelindungan setara atau lebih tinggi, pelindungan memadai yang mengikat, atau persetujuan subjek data dalam kondisi tertentu. Pengiriman prompt berisi data pribadi ke provider LLM di luar negeri bisa termasuk di sini. Menurut Hukumonline, PP 33/2026 sebagai peraturan pelaksana (ditetapkan 16 Juli 2026, 225 pasal) mulai berlaku 16 Januari 2027 (sumber). Ini alasan kuat untuk `allowed_providers` dan penyamaran PII sebelum keluar. Sudah dicek ke teks pasal dan sumber hukum: Pasal 4 ayat (2) memasukkan data keuangan pribadi sebagai data spesifik, dan Pasal 46 mewajibkan pemberitahuan tertulis 3 x 24 jam kepada subjek data dan lembaga (cara menghitung awal 3 x 24 jam tidak dijelaskan di pasalnya). PP 33/2026 Pasal 93 sampai 95 menjabarkan hak keberatan atas keputusan dari pemrosesan otomatis, jadi keputusan yang diambil guard perlu bisa dijelaskan lewat audit log. Denda administratif sampai 2% dari pendapatan tahunan (Pasal 185). Lembaga pengawas PDP belum terbentuk (diperkirakan efektif sekitar 2028), jadi belum ada standar teknis dari pengawas. Pasal 56 dan Pasal 36 sampai 39 belum dicek ke teks resmi.

- **OJK, Tata Kelola Kecerdasan Artifisial Perbankan Indonesia (29 April 2025).** Disebut OJK sebagai acuan minimal bagi bank, dan melengkapi antara lain POJK 11/2022 dan SEOJK 29/2022 (halaman OJK). Dari PDF 248 halaman itu, yang sudah dibaca: Kata Pengantar, Bab 1 dan 2, serta halaman Bab 6 dan 7 tentang pelindungan data, pihak ketiga, evaluasi/pengujian, pemantauan, dan jejak audit. Bab 4 dan 5 juga sudah dibaca (kolom bahasa Indonesia). Bab 3 (benchmark regulasi negara lain) sengaja tidak dibaca karena bukan kewajiban di Indonesia.
- **OJK, pedoman kode etik AI untuk fintech.** Diterbitkan 2023 dan menurut pemberitaan diperbarui Desember 2025 (Kontan; dari ringkasan berita, belum dibuka penuh).
- **Instansi pemerintah.** Berdasarkan pemberitaan, Perpres Peta Jalan AI dan Etika AI masih disiapkan (GovInsider), dan SE Menkominfo 9/2023 tentang etika AI serta regulasi BSSN 2024 disebut sebagai rujukan (Bisnis; dari ringkasan berita). Status terbaru perlu dicek ke sumber resmi sebelum `id-instansi` dibuat.

Panduan OJK berbasis prinsip, jadi pack tidak bisa "menjalankan" regulasi; ia hanya menerjemahkan prinsip ke aturan teknis yang disetujui penanggung jawab kepatuhan.

Kontrol perubahan kebijakan

- Kebijakan hanya berubah lewat git dengan persetujuan wajib dari peran yang ditetapkan (misalnya CODEOWNERS). Admin API berbasis peran menyusul setelah rilis awal.
- Setiap request mencatat versi dan hash kebijakan aktif (`audit.log_policy_version`), sehingga auditor bisa menelusuri aturan yang berlaku saat itu.
- Pack baru dijalankan dulu dalam `mode: shadow`; penegakan diaktifkan pihak berwenang setelah melihat hasilnya.

7. Pemetaan regulasi ke fitur

OmniRail adalah kontrol teknis pendukung. Tabel ini memetakan ketentuan yang sudah dikonfirmasi dari teks atau sumber hukum ke fitur yang sesuai, dan menandai apa yang tidak bisa dipenuhi oleh sebuah proxy.

Sumber	Ketentuan	Fitur OmniRail	Batas
UU 27/2022 Pasal 36	Pengendali data wajib menjaga kerahasiaan data pribadi	Penyamaran PII sebelum keluar; `store_raw_prompts: false`	Hanya untuk data yang terdeteksi

Sumber	Ketentuan	Fitur OmniRail	Batas
UU 27/2022 Pasal 37	Pengendali wajib mengawasi pihak yang terlibat dalam pemrosesan	`allowed_providers`; log mencatat provider dan model tiap request	Kontrak dan due diligence provider tetap urusan organisasi
UU 27/2022 Pasal 38 dan 39	Lindungi dari pemrosesan tidak sah; cegah akses tidak sah	Blokir credentials, API key proxy, `fail_mode: closed`	Tidak menggantikan kontrol akses sistem lain
UU 27/2022 Pasal 46	Pemberitahuan tertulis paling lambat 3x24 jam saat terjadi kegagalan pelindungan	Log pemblokiran dan deteksi plus versi kebijakan sebagai bahan investigasi	OmniRail tidak menilai apakah terjadi kegagalan pelindungan dan tidak mengirim pemberitahuan; peringatan otomatis ke tim belum ada
UU 27/2022 Pasal 56	Transfer data pribadi ke luar wilayah Indonesia hanya lewat jalur yang ditentukan	`allowed_providers` (misalnya hanya model lokal); PII yang tersamarkan tidak ikut keluar	Keabsahan transfer ditentukan pengendali data, bukan OmniRail
UU 27/2022 Pasal 4 ayat (2)	Menurut Hukumonline, data keuangan pribadi termasuk data pribadi spesifik	Pack `id-fintech` menjadikan entitas keuangan prioritas dengan aturan lebih ketat	Tingkat keketatan diputuskan penanggung jawab kepatuhan

Sumber	Ketentuan	Fitur OmniRail	Batas
OJK, Tata Kelola Kecerdasan Artifisial Perbankan Indonesia (Bab 2, Tabel 4)	Risiko GenAI mencakup kebocoran informasi sensitif (data privacy) dan keamanan informasi	Deteksi PII dan credentials sebagai kontrol mitigasi teknis	Bab 4 dan 5 sudah dibaca; Bab 3 tidak dibaca (benchmark luar negeri). Temuan Bab 4 dan 5 untuk OmniRail (nomor halaman cetak): pengawasan manusia dan eskalasi untuk keputusan berisiko tinggi (hal. 100 sampai 102), peran Direksi, Dewan Komisaris, dan Komite AI atau Komite Pengarah TI sesuai POJK 11/POJK.03/2022 (hal. 133 sampai 134), pengujian sebelum dipakai dan red-teaming (hal. 113, 121 sampai 122), pelaporan insiden AI (hal. 123), kebijakan pihak ketiga dengan pemantauan dan rencana cadangan (hal. 121). Ketentuan Bab 6 dan 7 dipetakan di tabel berikutnya
SE Menkominfo 9/2023 tentang etika AI	Disebut OJK memuat pelindungan data pribadi sebagai salah satu nilai	Policy pack yang bisa disesuaikan	Prinsip, bukan aturan teknis

Ketentuan tambahan dari panduan OJK (Bab 6 dan 7), dengan nomor halaman cetak dokumen:

Halaman	Ketentuan	Fitur OmniRail	Batas
165	Bank memperhatikan UU PDP dan regulasi OJK dalam penerapan AI, dan menyiapkan roadmap yang mencakup strategi privasi, struktur organisasi termasuk Petugas Pelindungan Data, serta kebijakan transfer data	Penyamaran PII; `allowed_providers` sebagai dukungan kebijakan transfer data	Struktur organisasi, DPO, dan roadmap privasi tetap urusan bank
166	Inventarisasi pemrosesan data disebut sebagai fondasi program privasi dan kewajiban hukum; privacy by design dan penilaian dampak privasi	Log jenis entitas yang terdeteksi dan jumlahnya (tanpa nilai) bisa menjadi masukan inventaris	Bukan inventaris resmi dan bukan penilaian dampak privasi
166, 168, 169	Bank tetap harus mengikuti standar saat memakai pihak ketiga; uji tuntas vendor berbasis risiko; vendor memberi jaminan alat AI mematuhi hukum dan keamanan data	`allowed_providers`; log provider dan model di tiap request	Uji tuntas dan kontrak vendor tetap urusan bank
167, 168	Fase evaluasi/testing menilai akurasi dan presisi serta aspek keamanan siber; hasilnya berupa keputusan kesesuaian, setelah ditinjau pemangku kepentingan dan pakar	Bagian **Evaluations** di bawah: metrik per entitas dan laporan uji sebagai bahan tinjauan	Keputusan kesesuaian dibuat manusia, bukan OmniRail

Halaman	Ketentuan	Fitur OmniRail	Batas
171, 172	Pemantauan mencakup integritas data, kinerja, peringatan kejadian, pelaporan; hasil pemantauan dan tindakan korektif didokumentasikan (keterlacakan)	Metrik OpenTelemetry, evaluasi berkala, laporan evaluasi yang tersimpan	Pemantauan seluruh model AI bank lebih luas daripada sebuah guard
192	Bank wajib memastikan ketersediaan jejak audit atas seluruh kegiatan penyelenggaraan AI untuk pengawasan, penegakan hukum, penyelesaian sengketa, verifikasi, pengujian, dan pemeriksaan lain, merujuk Pasal 53 POJK 11/POJK.03/2022	**Audit log per request**: waktu, provider, model, versi dan hash kebijakan, keputusan, jenis dan jumlah entitas (tanpa nilai mentah)	Jejak audit seluruh kegiatan AI bank lebih luas dari proxy; retensi log ditentukan bank

Sumber: teks UU PDP (Pasal 36 sampai 39 di Wikisource, Pasal 46 di Pasal.id), Hukumonline tentang Pasal 4 ayat (2) dan Pasal 56, serta PDF panduan OJK. Beberapa kutipan pasal berasal dari ringkasan pencarian dan perlu dicocokkan dengan naskah resmi oleh penanggung jawab kepatuhan.

Yang tidak bisa dipenuhi OmniRail dan tetap harus dikerjakan organisasi: persetujuan subjek data, penilaian dampak (DPIA), penunjukan pejabat pelindungan data, kontrak dengan provider LLM, notifikasi insiden ke subjek data dan lembaga, serta penilaian apakah suatu transfer ke luar negeri sah.

Cara menyesuaikan dengan aturan sebuah organisasi. Pack hanya titik awal. Organisasi menimpanya di `omnirail.yaml`, misalnya untuk lembaga keuangan yang kebijakan internalnya melarang data keluar negeri:

```
# contoh override; isi sebenarnya diputuskan penanggung jawab kepatuhan
policy_pack: id-fintech
ingress:
  pii:
    entities: [email, phone_id, credit_card, nik, npwp, bank_account]
    action: redact              # tanpa pemulihan di jawaban
  credentials:
    action: block
  policy:
    allowed_providers: [ollama] # hanya model lokal
mode: shadow                    # uji dulu, aktifkan penegakan setelah
ditinjau
```

Entitas tambahan, aturan kata, dan penanda klasifikasi (misalnya untuk instansi) ditambahkan dengan cara yang sama lewat aturan kustom tingkat 2.

8. Tech stack dan keputusan teknis

Prinsip: satu bahasa, satu binary, nol dependensi eksternal untuk MVP. Untuk pembangun tunggal, jumlah dependensi dan fitur dijaga kecil karena Rust memperlambat iterasi awal.

Keputusan	Pilihan	Alasan
Bahasa inti	**Rust**	Keputusan pembangun. Performa dan memori terprediksi, pustaka async (tokio, axum, reqwest) matang, dan crate `ort` tersedia bila classifier ONNX lokal dibutuhkan nanti. Konsekuensi: iterasi awal lebih lambat, jadi scope MVP dijaga ketat
State	Dalam memori, per request	Tabel token PII hidup selama satu request dan tidak pernah disimpan; Redis ditunda
Konfigurasi	YAML, divalidasi saat start	Satu file, mudah diaudit dan di-commit
Observabilitas	Log terstruktur + OpenTelemetry	Dasbor buatan sendiri tidak perlu di awal
Classifier (nanti)	Dipanggil via HTTP (Ollama atau layanan terpisah)	Menjaga binary tetap kecil dan tanpa GPU

Keputusan	Pilihan	Alasan
Pengujian	Ollama lokal + mock server; Claude API dan Gemini API hanya untuk uji integrasi akhir	Tanpa biaya token saat pengembangan
Kunci	Dua kunci: kunci OmniRail untuk aplikasi, kunci provider (Anthropic, Gemini, OpenAI) hanya di proxy	Aplikasi tidak pernah memegang kunci provider

Catatan: langganan Claude di claude.ai tidak termasuk akses API. Untuk upstream Claude dibutuhkan API key dari Claude Console (bayar per token). Gemini dan OpenAI juga memakai API key sendiri dari penyedianya.

9. Threat model dan batas klaim

OmniRail MVP mengurangi risiko tertentu; ia tidak menjamin keamanan. Klaim publik dibatasi pada kolom "Dicakup MVP" di bawah.

Ancaman	Dicakup MVP	Catatan
PII berformat tetap (email, kartu, NIK, nomor telepon) dan credentials (API key, token, password) terkirim ke provider	Sebagian	Regex + validasi dan pola secret; kasus tepi, format tak lazim, dan secret tanpa pola bisa lolos
PII bebas-bentuk (nama, alamat)	Tidak	Butuh NER; ditunda
Prompt injection langsung	Tidak	Hanya deny-list pola, mudah dilewati; classifier menyusul
Indirect injection dan penyalahgunaan tool	Tidak	Butuh SDK atau MCP gateway; ditunda
Output JSON rusak atau tak sesuai schema	Ya	Perbaikan sintaks lokal; pelanggaran schema dicatat, retry opsional
Kebocoran lewat log	Ya	`store_raw_prompts: false` secara default; nilai PII tidak pernah ditulis
Kebocoran kunci	Sebagian	Kunci provider hanya di proxy; rotasi dan rate limit per kunci ditunda
Proxy gagal atau lambat	Ya	`fail_mode` per rute, health check, timeout ke upstream

Batas lain yang harus tertulis di README: lampiran dan gambar tidak diperiksa, tokenisasi berlaku per request (tidak lintas sesi), dan OmniRail tidak mengklaim kepatuhan hukum apa pun, termasuk UU Pelindungan Data Pribadi. Itu tetap tanggung jawab pengguna.

10. Evaluations

Evaluations adalah cara mengukur apakah OmniRail makin baik dari rilis ke rilis, dan bukti bahwa guard bekerja. Panduan OJK menempatkan evaluasi dan pengujian sebagai fase tersendiri yang menilai akurasi, presisi, dan aspek keamanan siber (halaman 167 dan 168). Prinsip yang sama dipakai di sini: setiap perubahan aturan atau kode harus punya angka sebelum dan sesudah.

Tiga jenis evaluasi

1. **Evaluasi offline.** Menjalankan set uji berlabel (format sama dengan `uji_pii_id.csv`: `id`, `kategori`, `teks`, `diharapkan`, `cakupan_mvp`, `catatan`) lewat `omnirail eval`.
2. **Evaluasi performa.** Mengukur tambahan latensi dan throughput jalur deterministik.

3. **Evaluasi lapangan.** Dalam `mode: shadow`, sampel temuan ditinjau manusia untuk memperkirakan precision pada data nyata.

Metrik	Cara menghitung	Sumber data	Kapan dijalankan
Recall per entitas	Temuan benar dibagi semua yang seharusnya terdeteksi	Baris positif	Tiap perubahan kode atau pack
Precision per entitas	Temuan benar dibagi semua temuan	Baris positif dan negatif	Tiap perubahan kode atau pack
Tingkat false positive	Baris negatif yang salah ditandai dibagi semua baris negatif	Baris negatif	Tiap perubahan kode atau pack
Tingkat blokir credentials	Baris kredensial yang diblokir dibagi semua baris kredensial	Baris kredensial	Tiap perubahan kode atau pack
Deteksi injection (deny-list)	Baris injeksi yang tertangkap dibagi semua baris injeksi	Baris injeksi	Tiap perubahan pack
Pemulihan token	Token yang kembali ke nilai asli dibagi semua token	Baris positif	Tiap perubahan kode
Latensi p50 dan p99	Selisih waktu dengan dan tanpa proxy	Benchmark sintetis	Tiap rilis
Precision lapangan	Temuan yang dinilai benar oleh peninjau dibagi sampel yang ditinjau	Sampel `shadow`	Berkala setelah dipakai

Cara evaluasi dijalankan dan dicatat

- Hasil tiap run disimpan sebagai berkas JSON bernomor versi (kode, pack, dataset, waktu), ditambah ringkasan yang bisa dibaca manusia. Dengan begitu perkembangan antar rilis bisa dibandingkan dan didokumentasikan.
- Run pertama menjadi **baseline**. Ambang lolos ditetapkan dari baseline, bukan ditebak sekarang.
- Di CI, perubahan gagal bila recall turun atau false positive naik melewati ambang tersebut.
- Dataset dipisah menjadi `dev` (boleh dilihat saat menyetel aturan) dan `holdout` (hanya dijalankan sebelum rilis), agar aturan tidak sekadar disetel agar lulus uji.

- Semua data uji adalah data rekaan. Data nyata hanya boleh masuk setelah dianonimkan dan disetujui penanggung jawab data.
- Kasus gagal (terlewat dan salah tandai) dicatat satu per satu dengan alasannya, sebagai bahan perbaikan berikutnya.
- Setiap policy pack wajib punya set uji sendiri (`should_detect` dan `should_ignore`) dan ikut dievaluasi.

Audit log dan evaluasi saling melengkapi. Evaluasi menjawab "seberapa baik aturannya", sedangkan audit log menjawab "apa yang terjadi pada request tertentu". Keduanya mengacu pada versi dan hash kebijakan yang sama.

11. Tampilan uji (playground)

Tampilan uji adalah satu halaman web lokal, disajikan langsung oleh binary OmniRail, untuk mencoba kebijakan dan melihat hasilnya tanpa menulis kode. Karena berupa berkas statis yang tertanam di binary, tidak ada bahasa atau layanan tambahan.

Tab "Coba"

- Kolom kiri: kotak teks dan pilihan pack, mode (`enforce` atau `shadow`), serta provider.
- Kolom kanan: teks asli dengan bagian yang terdeteksi disorot, teks setelah penyamaran (dengan token), keputusan (lolos, diblokir, atau hanya dicatat), daftar temuan (jenis entitas, validator, aksi, aturan atau pack yang cocok), dan waktu proses.
- Tombol "kirim ke provider" memakai kunci yang tersimpan di proxy dan menampilkan jawaban setelah pemulihan token.

Tab "Evaluasi"

- Pilih dataset dan pack, jalankan, lalu lihat metrik per entitas.
- Daftar kasus gagal dengan penjelasan, terpisah antara terlewat dan salah tandai.
- Perbandingan dengan baseline atau run sebelumnya, supaya terlihat apakah suatu perubahan memperbaiki atau merusak.

Batasan

- Hanya dapat diakses dari mesin lokal atau lewat kunci admin; mengikuti kontrol perubahan kebijakan yang sama.
- Input tidak disimpan, dan nilai sensitif di tampilan dapat disamarkan.
- Urutan pengerjaan: CLI `omnirail test` dan `omnirail eval` lebih dulu (tahap 3), halaman web satu halaman menyusul di tahap 5. Dasbor telemetri berskala penuh tetap ditunda.

12. Roadmap solo

Lima tahap sampai rilis publik pertama; tiap tahap punya kriteria selesai yang bisa diperiksa. Belum ada tanggal: tentukan setelah tahap 1 menunjukkan kecepatan kerja sebenarnya.

1. **Kerangka proxy.** Endpoint non-streaming, upstream Ollama, config YAML. *Selesai bila* SDK OpenAI mendapat jawaban lewat proxy.
2. **Jalur provider.** Satu format internal dan satu adapter per provider (OpenAI passthrough, Anthropic Messages API, Gemini API), untuk teks. Urutan pengerjaan: Anthropic dulu, lalu Gemini, lalu OpenAI. *Selesai bila* uji integrasi lulus terhadap tiap provider. Catatan Gemini: dari dokumentasi Vertex AI dan contoh yang mengikuti format Google, strukturnya konsisten (endpoint v1beta/models/MODEL:generateContent, header x-goog-api-key, contents berisi parts, systemInstruction, generationConfig dengan responseMimeType dan responseSchema, respons berisi candidates dan usageMetadata). Halaman resmi ai.google.dev belum bisa dibuka, jadi cek sekali lagi ke sana sebelum menulis adapter.
3. **PII tokenisasi.** Entitas Indonesia, deteksi credentials, tokenisasi dan pemulihan, set uji berlabel buatan sendiri, dan eval harness (omnirail eval). *Selesai bila* recall dan precision per entitas tercatat sebagai baseline.
4. **Validasi JSON.** Schema check dan perbaikan sintaks. *Selesai bila* pelanggaran schema dan perbaikan terhitung di metrik.
5. **Rilis awal.** README dengan batas klaim, benchmark latensi, tampilan uji satu halaman, dan 5 sampai 10 percakapan dengan calon pengguna. *Selesai bila* ada umpan balik tertulis yang menentukan prioritas berikutnya.

Setelah itu, urutan ditentukan umpan balik: streaming, adapter LiteLLM, classifier injection, topic control semantik, tool/MCP governance, SDK, dasbor. Arah jangka panjang ada di bagian Arah pengembangan setelah MVP.

13. Arah pengembangan setelah MVP

Bagian ini hanya arah, bukan komitmen. Semuanya bergantung pada hasil validasi awal: uji `uji_pii_id.csv` terhadap LiteLLM dengan Presidio, dan wawancara pengguna. Kalau Presidio dengan recognizer lokal ternyata sudah cukup, arah yang paling realistis adalah lapis 3 di bawah.

Lapis 1. Pengembangan langsung (inti produk)

- Streaming, tool call, dan gambar, yang sengaja ditunda dari MVP.
- NER lokal lewat ONNX (`ort`) untuk nama, alamat, dan nama instansi. Ini menutup celah terbesar MVP.

- Deteksi injeksi yang lebih baik dari deny-list, dengan daftar uji injeksi di `uji_pii_id.csv` sebagai bahan awal.
- Kustomisasi tingkat 4 (WASM atau webhook) untuk aturan yang tidak bisa ditulis di YAML.

Lapis 2. Nilai tambah

- Admin API dan konsol peran: persetujuan perubahan kebijakan oleh peran berwenang, melengkapi git dan CODEOWNERS.
- Laporan bukti pendukung: ekspor audit log dan hasil evaluasi menjadi dokumen untuk auditor internal, dipetakan ke OJK dan UU PDP. Wording-nya "bukti pendukung", bukan klaim patuh.
- Dasbor pemantauan: temuan per hari, tingkat blokir, dan tren false positive dari mode shadow.
- Draf catatan insiden otomatis saat kredensial terdeteksi atau diblokir, selaras dengan saran OJK soal pelaporan insiden AI.

Lapis 3. Ekosistem

- Marketplace policy pack: pack id-fintech, id-ecommerce, dan id-instansi yang dikurasi, ditandatangani, dan wajib punya tes. Kurasi sulit ditiru, jadi di sini nilai jangka panjang paling besar.
- Benchmark terbuka PII dan kredensial berbahasa Indonesia sebagai rujukan yang berdiri sendiri.
- Plugin guardrail untuk gateway lain (LiteLLM, Presidio) sebagai jalur adopsi tercepat kalau menjadi gateway sendiri terasa berat.
- SDK dan sidecar untuk aplikasi yang tidak bisa lewat proxy.

Lapis 4. Butuh tim

- Versi on-premise untuk instansi dan bank, dengan dukungan dan SLA.
- Penilaian risiko model dan vendor, misalnya checklist pihak ketiga seperti saran OJK Bab 5.
- Pengujian red-team terjadwal dengan serangan sintetis tiap rilis.

Fokus yang disarankan: laporan bukti pendukung ditambah marketplace pack, karena keduanya memakai kekuatan unik OmniRail (konteks Indonesia dan bukti terukur) dan tidak bisa disalin cepat. Streaming dan NER penting, tetapi pesaing juga akan menyusul di sana.

14. Metrik, risiko, dan pertanyaan terbuka

Target angka sengaja belum ditulis: tetapkan setelah baseline tahap 3 dan 5, jangan ditebak.

Metrik keberhasilan MVP

- Overhead latensi p50 dan p99 pada jalur deterministik (diukur tanpa dan dengan proxy).
- Recall dan precision deteksi PII per entitas pada set uji berlabel.
- Persentase output JSON yang diperbaiki tanpa retry.
- Waktu dari mengunduh binary sampai request pertama berhasil.

Risiko	Dampak	Mitigasi
Scope creep dari daftar fitur v1.0	MVP tidak pernah rilis	Tabel scope di atas jadi pagar; fitur baru masuk setelah tahap 5
False positive PII merusak jawaban	Pengguna mematikan guard	Mode `shadow`, log deteksi, entitas bisa dimatikan satu per satu
Streaming memecah token PII	Kebocoran atau jawaban rusak	Non-streaming dulu; desain buffer token sebelum streaming dirilis
LiteLLM atau gateway lain menambah fitur serupa	Diferensiasi menyempit	Pegang keunggulan lokalisasi Indonesia, footprint kecil, dan adapter ke gateway tersebut
Kebutuhan pengguna tidak sesuai hipotesis	Fitur tidak dipakai	Wawancara di tahap 5 sebelum membangun fitur lanjutan

Keputusan dan pertanyaan terbuka

- **Diputuskan:** bahasa inti Rust.
- **Diputuskan:** lisensi Apache 2.0.
- **Diputuskan:** adapter OpenAI, Anthropic, dan Gemini sejak MVP. Risiko: tiap adapter menambah kasus tepi (tool call, streaming, batas panjang), jadi MVP tetap teks saja dan adapter dikerjakan satu per satu.
- **Terbuka:** daftar 5 sampai 10 calon pengguna. Pembangun menjadi pengguna pertama; wawancara eksternal menyusul dan bahan persiapannya ada di bagian berikutnya.

15. Persiapan wawancara pengguna

Tujuan wawancara adalah menguji hipotesis di bagian Ringkasan, bukan menjual produk. Gunakan contoh rekaan; jangan minta data asli.

Profil yang dicari (peran, bukan nama)

- Engineer atau tech lead di startup yang sudah memakai LLM API di produknya.
- Engineer di fintech, asuransi, atau e-commerce yang menangani data pelanggan Indonesia.
- Tim data atau AI internal yang membangun chatbot layanan pelanggan.
- Konsultan atau agensi yang membangun solusi LLM untuk klien.
- Penanggung jawab keamanan atau pelindungan data di perusahaan seperti di atas.

Pertanyaan

1. Bagaimana tim Anda menangani data pribadi sebelum dikirim ke LLM saat ini?
2. Alat apa yang sudah dicoba (LiteLLM, Presidio, lainnya), dan apa yang kurang?
3. Jenis data apa yang paling Anda khawatirkan bocor?
4. Pernah ada kejadian atau nyaris kejadian? Apa yang terjadi?
5. Siapa yang memutuskan memasang guard, dan apa yang bisa membuatnya ditolak?
6. Seberapa besar tambahan latensi yang masih bisa diterima?
7. Provider LLM apa yang dipakai, dan apakah berganti-ganti?
8. Kalau ada alat yang menyelesaikan ini, apa yang harus benar-benar ada agar Anda memakainya?

Hasil wawancara pertama (pembangun, konteks fintech)

Ini hipotesis dari pembangun sendiri, bukan validasi pihak lain.

- Data pribadi ditangani mengikuti standar nasional dan OJK.
- Belum mencoba LiteLLM, Presidio, atau alat lain, sehingga celah belum teruji.
- Kekhawatiran utama: credentials, dengan penyesuaian ke aturan OJK dan standar nasional.
- Belum ada insiden atau nyaris insiden.
- Pemasangan dan perubahan guard seharusnya hanya oleh peran yang berwenang.
- Provider yang dipakai: Claude, Gemini, dan ChatGPT.
- Syarat pemakaian: customisasi sesuai regulasi dan peran penanggung jawab, serta cara mencoba tanpa risiko (mode `shadow`).